Vulnerability Assessment
of
2 Hidden Systems

Sam Miller

ISA 4220

Fall Semester

December 1, 2025

PUBLIC PORTFOLIO COPY

Academic vulnerability assessment conducted in a classroom lab environment.
Findings and recommendations describe training systems.

The VM MAC address and scanner report ID were removed from screenshots.

Table of Contents

Executive Summary 3

Technical Summary 4

HIGH Findings 5

Windows: 5

Details of High Findings, Recommendations and Fixes for Windows: 5

Linux: 5

Details of High Findings, Recommendations and Fixes for Linux: 5

MEDIUM Findings 14

Windows: 14

Details of High Medium, Recommendations and Fixes for Windows: 14

Linux: 14

Details of Medium Findings, Recommendations and Fixes for Linux: 14

Annexes 28

Greenbone scan results 28

Nmap Scan Results – Linux Server 29

Nmap Scan Results – Windows Server 29

Vulnerability Ranking Scale 29

References 31

Executive Summary

The purpose of this vulnerability assessment is to identify and analyze potential security issues within the lab network. The scan revealed that one active, hidden Linux server was found at IP address 192.168.1.30. At the same time, the Windows server was unreachable. The Linux server showed multiple High and Medium severity vulnerabilities, High vulnerabilities, including a backdoored FTP service (vsftpd 2.3.4) and end-of-life software such as Apache 2.2.8 and OpenSSH 4.7p1. Medium issues found in the scan involved weak encryption protocols, insecure SSH cipher suites, and Apache directory indexing.

If threat actors exploit these identified risks, they can result in severe security compromise, remote code execution, and data loss if not properly contained and removed. The recommended actions for server security verification include isolating the server, removing any identified backdoors, turning off unnecessary services, patching the operating system and applications, and enforcing host-based security system rules. Services must be modernized to meet security standards and re-establish security posture. Following these actions, verification scans through Kali Linux should confirm that the high-risk vulnerabilities have been remediated. The overall summary is that the server is in a critical, insecure environment and requires immediate remediation.

Technical Summary

The network scan to identify any active hosts and their respective service versions was done using Nmap (nmap -sS -sV -O 192.168.1.0/24). The scan revealed one hidden Linux system and open ports, including FTP (21), SSH (22), HTTP (80), HTTPS (443), PostgreSQL (5432), MySQL (3306), and a suspicious shell (1524). The network scan did not reveal any Windows hosts, did not respond to further investigator scans, such as ICMP or TCP SYN probes, and the Windows server was determined to be unreachable.

Linux host's Nmap results revealed that the hidden server has outdated services and numerous open ports. These findings were inspected further using Greenbone Vulnerability Manager (GVM), which detected a total of 46 vulnerabilities, comprised of 15 high and 31 Medium severity, scored under CVSS v3.1. Some examples include the vsftpd backdoor (CVE-2011-1578), the Apache mod_status disclosure (CVE-2007-1858), and the OpenSSH CBC-mode flaw (CVE-2008-5161). The combination of outdated software, backdoors, and open services shows Linux's insecure state. Screenshots and the filtered Greenbone report are provided in the Annex.

HIGH Findings

Windows:

Details of High Findings, Recommendations and Fixes for Windows:

1. Details of findings

    1.1. No findings.

2. Recommendation and fixes

    2.1. No findings.

Linux:

Details of High Findings, Recommendations and Fixes for Linux:

1. **Operating System (OS) End of Life (EOL) Detection (Port: General/TCP) Findings:**

    The server that is currently running the Linux operating system is on a legacy version of kernel 2.6, which has reached end of life, meaning that the operating system is in an unsupported state as it is no longer receiving critical security updates or kernel patches, leaving known exploits such as privilege escalation and unaddressed local root vulnerabilities (Timalsina, 2024). Threat actors can take advantage of these chain kernel flaws and outdated library exploits to gain persistent root-level access and disable controls like SELinux or AppArmor.

    1.1. **Operating System (OS) End of Life (EOL) Detection (Port: General/TCP) Recommendations and Fixes:**

    Upgrade the legacy Linux operating system to a supported version, such as Ubuntu 24.04 LTS (Stanley, 2025). To ensure a smoother update, perform a clean installation of

the verified image, apply all patches, enable automatic security updates, and revalidate with vulnerability scans after migration.

2. **Distributed Ruby (dRuby/DRb) Multiple RCE Vulnerabilities (Port: 8787/tcp)**

   Findings:

   Distributed Ruby, otherwise known as dRuby/DRb, has multiple high vulnerabilities related to the finding. dRuby as a service allows deserialization of trusted Ruby objects over the 8787 TCP port, which allows attackers to exploit and execute malicious Ruby code with application user privileges (CVE-2009-4492). This can lead to unauthorized remote code execution risk that can compromise the host system.

   2.1. **Distributed Ruby (dRuby/DRb) Multiple RCE Vulnerabilities (Port: 8787/tcp)**

   Recommendations and Fixes:

   To address this high vulnerability, disable the TCP port 8787 through iptables if dRuby is not required (CVE-2009-4492). If necessary, bind the service to localhost only, apply Ruby updates (3.3 or higher), enforce TLS authentication, and ensure that it has restricted access using firewall rules.

3. **Possible Backdoor: Ingreslock (Port 1524) Findings:**

   Nmap identified an open service on TCP Port 1524 labeled as “Bash Shell (root backdoor).” This is a clear identification of the system being compromised with a pre-installed malicious binary that allows attackers to have remote root access without proper authentication. Backdoors of this type allow adversaries to bypass security controls, let them have persistent access, and allow them to execute arbitrary commands. According to MITRE ATT&CK

(2025), unauthorized backdoor shells are a critical persistence and privilege escalation mechanism.

3.1. **Possible Backdoor: Ingreslock (Port 1524) Recommendations and Fixes:**

The following is recommended to fix the Bind Shell backdoor: first, immediately isolate the system from the network to prevent active exploitation; then, identify and remove the malicious binary after preserving evidence for forensics; and finally remove the binary using standard Linux tools such as lsof, ss, pkill, and rm. It is recommended to do a complete rebuilding of the server from a trusted image, which is the most reliable solution, since the backdoored host cannot be trusted to be secure even after removal of the immediate process. Follow-up verification can be done by scanning the host to confirm that port 15243 is no longer accessible. This type of persistence mechanic is well-documented in security frameworks, such as MITRE ATT&CK, which lists backdoors as a critical tactic used by threat actors to maintain access to compromised systems (MITRE, n.d.).

4. **TWiki XSS and Command Execution Vulnerabilities (Port: 80/tcp) Findings:**

During the initial scan, the TWiki web application was flagged as a high vulnerability because it allows attackers to execute arbitrary operating system commands or inject malicious JavaScript through crafted URLs (Carnegie Mellon University, 2008). Vulnerabilities, such as CVE-2014-7235 and CVE-2014-7236, can be exploited to gain complete control of the web host.

4.1. **TWiki XSS and Command Execution Vulnerabilities (Port: 80/tcp)**

Recommendations and Fixes:

To prevent malicious JS code from being injected, upgrade TWiki to its latest supported release (CVE-2014-7236). Sanitize all user inputs to ensure that nothing malicious will run, apply patches for XSS and command injection flaws, and restrict admin access to only trusted networks.

5. **Apache Tomcat AJP RCE (Ghostcat) (Port: 8009/tcp) Findings:**

An outdated version of the Apache Tomcat connector was found within the Greenbone scan. The Ghostcat is a local file vulnerability which can lead to remote file inclusion and code execution (CVE-2020-1938) (Logan, 2020). Attackers can use these exploits to read configuration files and deploy web shells.

5.1. **Apache Tomcat AJP RCE (Ghostcat) (Port: 8009/tcp) Recommendations and Fixes:**

Upgrade Tomcat to its latest version (9.0.31 or newer), disable the AJP connector if not required for the service, and limit access to administrative paths only (Logan, 2020) (CVE-2020-1938). Review all the uploaded files and ensure that they are properly sanitized to prevent any malicious code execution.

6. **PHP < 5.3.13, 5.4.x < 5.4.3 Multiple Vulnerabilities (Port: 80/tcp) Findings:**

PHP versions 5.3-5.3 are no longer supported, leaving the host open to containment of several critical remote code execution vulnerabilities, including CVE-2012-1823 (Mammen et al., 2020), that allow arbitrary code execution through HTTP crafted requests. This vulnerability is an exploit with a high impact as it leads to attackers seeking unpatched PHP

instances to create initial access points for web servers, where arbitrary PHP code can be put on the affected computer.

6.1. **PHP < 5.3.13, 5.4.x < 5.4.3 Multiple Vulnerabilities (Port: 80/tcp)**

Recommendations and Fixes:

Upgrade PHP to its latest version (8.2) and remove any extensions that are out of date, which can cause a deterioration of the service. Configure the open_basedir file restrictions and run PHP-FPM under a non-root user (CVE-2012-1823) (Mammen et al., 2020). Ensure that the fixes are patched by evaluating them on hosted web applications before deploying them into production.

7. **vsftpd Compromised Source Packages Backdoor Vulnerability (Ports: 21 & 6200)**

Findings:

The server runs vsftpd 2.3.4, which contains a documented backdoor vulnerability (CVE-2011-1578). This vulnerability was introduced in a malicious version of vsftpd and allows remote attackers to execute a shell automatically if a username ending with ":)" is used. This vulnerability is exposed to the threat of a denial-of-service attack, caused by only a limited number of connections allowed (Rapid 7, 2018). The exploitation provides immediate root shell access to the system.

7.1. **vsftpd Compromised Source Packages Backdoor Vulnerability (Ports: 21 & 6200)**

Recommendations and Fixes:

Disable and remove vsftpd from the host using package management tools such as systemctl stop, systemctl disable, and apt remove --purge vsftpd. If file transfer capabilities are required, then a more secure alternative, such as SFTP over SSH, should

be used instead. Once the services have been removed or replaced, a verification scan should be run to make sure that port 21 is closed. This vulnerability highlights the dangers of running outdated, untrusted software versions in production environments (MITRE, 2018).

8. **DistCC RCE Vulnerability (CVE-2004-2687) (Port: 3632/tcp) Findings:**

   The DistCC is a compiler daemon that allows unauthorized users to submit and execute code remotely over the TCP port 3632 (CVE-2004-2687, 2004). The compiler exploits its victims by executing malicious code, commonly used to gain system control.

   8.1. **DistCC RCE Vulnerability (CVE-2004-2687) (Port: 3632/tcp) Recommendations and Fixes**:

   The service was disabled in 2002 and commonly appears on misconfigured servers; it should be disabled immediately, and its respective port should be blocked completely on iptables (CVE-2004-2687, 2004).

9. **PostgreSQL Default Credentials (PostgreSQL Protocol) (Port 5432) Findings:**

   The database is shown to be running on an outdated version as well, which can allow authentication bypass if there are any improperly configured trust settings (PostgreSQL, 2025). The Greenbone scan reported a missing patch that could permit privilege escalation from within the database.

   9.1. **PostgreSQL Default Credentials (PostgreSQL Protocol) (Port 5432) Recommendations and Fixes:**

   Update PostgreSQL to the latest long-term supported version available and configure the access rules, which can be found in the pg_hba.conf, allowing connections only from

approved IP ranges, such as SCRAM-SHA_256 authentication (PostgreSQL, 2025). Reconfigure the default configurations and log all authentication attempts into the database for auditing purposes.

10. **UnrealIRCd Authentication Spoofing Backdoor (Port: 6697) Findings:**

UnrealIRCd is vulnerable to spoofing vulnerabilities as it is affected by CVE-2010-2075 due to an error in the authentication function in its modules script (INCIBE, 2024). Successful use of this exploit can allow remote attackers to spoof certificate fingerprints and log in as another user in the system.

10.1. **UnrealIRCd Authentication Spoofing Backdoor (Port: 6697) Recommendations and Fixes:**

Upgrade UnrealIRCd to a verified updated image (3.2.8.1 or higher) and validate its installation packages using SHA256 signatures (INCIBE, 2024). Restrict this service to IRC for administrative purposes only and reverify its integrity after each patch it goes through.

11. **Test HTTP Dangerous Methods (Port 80) Findings:**

The current detected web server version is Apache 2.2.8, which is out of date and no longer receives adequate security updates, making it not secure enough to be run on a server. Multiple vulnerabilities can arise from this, such as: CVE-2007-1858 and CVE-2009-1195 (OWASP, 2009), which allow unauthorized users to view configuration files or escalate privileges.

11.1. **Test HTTP Dangerous Methods (Port 80) Recommendations and Fixes:**

Disable Apache 2.2.8 and install a current release; Apache 2.4 or higher. The new

configuration should disable directory listing, remove version banners, enforce HTTP-only access, and restrict file ownership permissions to reduce the attack surface of this service (OWASP, 2009).

12. Java RMI Insecure Default Configuration (Port: 1099/tcp) Findings:

For Java Remote Method Invocation (RMI) to operate, it relies on the default configuration of the RMI registry and activation services. This configuration (CVE-2017-3241, 2017) allows classes to be loaded from a remote source, potentially leading to remote code execution. The vendor identifies this behavior as a design feature (NMAP), which can provide a substantial security risk if left unrestricted.

12.1. **Java RMI Insecure Default Configuration (Port: 1099/tcp) Recommendation and Fixes:**

Fully disable the Java RMI on any public interface and restrict it to localhosts only. Ensure that Java is upgraded and patched to JRE 8u121 or newer (Oracle Critical Patch Update January 2017). Configure the SSL transport and enforce code restrictions to ensure nothing malicious can be pushed.

13. **FTP Brute Force and Default Credentials Reporting (Port: 21/tcp) Findings:**

This vulnerability is flags anonymous and weak credentials that were accepted by the FTP service, which allows unlimited login attempts. (Lee, 2025) Threat actors can use this vulnerability to use brute-force access or log in anonymously to retrieve files or plant malicious data.

13.1. FTP Brute Force and Default Credentials Reporting (Port: 21/tcp)

Recommendation and Fixes:

Ensure that anonymous FTP logins are disabled, enforce password complexity requirements, and implement rate-limiting to ensure that brute force attempts are unable to be made (OWASP Authentication, 2025). Ensure that SSH with key-based authentication is enabled.

14. **SL/TLS: OpenSSL CCS Main in the Middle Security Bypass Vulnerability (Port: 5432/tcp) Findings:**

The default of OpenSSL, is prone to a “security bypass vulnerability” (Pentest Tools, 2013), meaning that, by itself, OpenSSL does not enforce sufficient restrictions on these specific messages, which can allow an attacker to perform a man-in-the-middle (MITM) attack. Successful exploitation can lead to a session hijack or unauthorized data exposure.

14.1. SL/TLS: OpenSSL CCS Main in the Middle Security Bypass Vulnerability (Port: 5432/tcp) Recommendation and Fixes:

Recommendation is to use OpenSSL version 1.0.1h or higher. To ensure extra security, regenerate all SSL keys and certificates and disable any legacy SSL protocols such as SSLv2/3 (Pentest Tools, 2013).

MEDIUM Findings

Windows:

Details of Medium Findings, Recommendations and Fixes for Windows:

1. Details of findings

   1.1. No findings.

2. Recommendation and fixes

   2.1. No findings.

Linux:

Details of Medium Findings, Recommendations and Fixes for Linux:

1. **TWiki Cross-Site Request Forgery Vulnerability (Sep 2010) / Twiki CSRF Vulnerability (Port: 80) Findings:**

   The web application on the Twiki instance can allow cross-site request forgery, also known as CSRF, caused by missing validation tokens. (TWiki, 2010). The attacker can take advantage of this and pretend to be a valid token, using this request to embed malicious forms or links. This vulnerability could enable configuration changes or unauthorized content creation without the user's knowledge.

   1.1. **TWiki Cross-Site Request Forgery Vulnerability (Sep 2010) / Twiki CSRF Vulnerability (Port: 80) Recommendation and Fixes:**

   As a countermeasure against this attack, it is recommended that the user apply the hotfix by upgrading to the latest patched production TWiki-5.0.1 or higher. (Twiki, 2010). The recommendation is that we restrict web server software access to the web pages server by Tiki only.

2. **Anonymous FTP Login Reporting (Port: 21/tcp) Findings:**

   The FTP service has a medium vulnerability that permits anonymous logins. (Lee, 2025). While not immediately exploitable for complete system control, it allows the risk of information disclosure by letting anyone list or download files.

   2.1. **Anonymous FTP Login Reporting (Port: 21/tcp)Recommendation and Fixes:**

   Disable anonymous access and require individual user accounts for any operation that requires FTP (Lee, 2024). Where file sharing is required, use SFTP for encrypted and more secure transfers.

3. **jQuery < 1.9.0 XSS Vulnerability (Port: 80/tcp) Findings:**

   This vulnerability falls under Common Gateway Interface (CGI), abuse (Tenable, 2020). This means that the remote web server is affected by a cross-site scripting (XSS) vulnerability, which can allow attackers to run arbitrary scripts in users' browsers, like Twiki's vulnerability.

   3.1. jQuery < 1.9.0 XSS Vulnerability (Port: 80/tcp) Recommendation and Fixes:

   Upgrade the jQuery library to version 3.7 or newer (Tenable, 2020) and ensure that the Content Security Policy (CSP) headers are implemented to mitigate the risk of script injection attacks.

4. **TWiki < 6.1.0 XSS Vulnerability Medium Findings:**

   The Twiki content management system is operating a version below 6.1.0, which allows cross-scripting (CSS) through web parameters (CVE-2018-20212, 2018). This means that an attacker can get to a target site and execute malicious code.

4.1. TWiki < 6.1.0 XSS Vulnerability Medium Recommendation and Fixes:

Update to version 6.1.0 or later to avoid CSS through web parameters and ensure that all the input fields are sanitized properly to prevent any unauthorized scripts or injections.

5. **Samba 3.0.0 ≤ 3.0.25rc3 MS-RPC Exposure (Port: 445/tcp) Findings:**

In these specific versions of Samba, there is an exposure, known as a flaw, in MS-RPC communication (Red Hat, 2025). This allows remote attackers to execute arbitrary commands through shell metacharacters that could potentially allow crafting requests to crash the service or leak memory data.

5.1. Samba 3.0.0 ≤ 3.0.25rc3 MS-RPC Exposure (Port: 445/tcp) Recommendation and Fixes:

Restrict SMB traffic to internal subnets only to limit the area of attack (Red Hat, 2025) and upgrade to the latest supported Samaba version 4.x or higher.

6. **SSL/TLS: Report Weak Cipher Suites (Port: 5432/tcp) Findings:**

Currently, SSL/TLS is running on weak ciphers; this matters because during an SSL handshake between the client and a server, a cipher is used to negotiate between the two of them (Red Hat, 2024). If it is weak (less than 128 bits), it becomes susceptible to cryptographic attacks that could weaken the encrypted session's confidentiality.

6.1. SSL/TLS: Report Weak Cipher Suites (Port: 5432/tcp) Recommendation and Fixes:

Strengthen the current ciphers by reconfiguring the system to use only modern ciphers such as AES-GCM or ChaCha20 and enforce TLS 1.2 or higher (Red Hat, 2024).

Apache, which runs on this server, has instructions to disable weak ciphers, so ensure that it is correctly enabled to ensure the system stays strengthened.

7. **SSL/TLS: Deprecated SSLv2 and SSLv3 Protocols (Port: 5432/tcp) Findings:**

The host is currently accepting connections using SSLv2 and SSLv3, which have been deprecated over time and suffer from cryptographic flaws that have been exploited over several years (Forta, 2025). An attacker can take advantage of these issues and conduct man-in-the-middle attacks or decrypt communications between the affected service and client and intercept sensitive information.

7.1. SSL/TLS: Deprecated SSLv2 and SSLv3 Protocols (Port: 5432/tcp)

Recommendation and Fixes:

Go to the application document within the server and disable SSL 2.0 and SSL 3.0 and use TLS 1.0 or newer (Forta, 2025). This ensures that applications are no longer running on flawed cryptography.

8. **HTTP Debugging Methods (TRACE/TRACK) Enabled (Port: 80/tcp) Findings:**

Currently, the web server allows TRACE and TRACK HTTP methods, which are used to debug web server connections (Tenable, 2002). This can allow echo back user input and allow cross-site tracing attacks, making it susceptible to CVE-2010-0386.

8.1. HTTP Debugging Methods (TRACE/TRACK) Enabled (Port: 80/tcp)

Recommendation and Fixes:

Disable the HTTP methods of TRACE and TRACK in the Apache configuration file (Tenable, 2002) and use an Nmap test to verify that these methods are no longer responding.

9. **phpinfo() Output Reporting (HTTP) (Port: 80/tcp) Findings:**

   The scan revealed a PHP file that is used for debugging purposes. This file is insecure, and various PHP applications may also include the same file (Tenable, 2003). If an attacker can access phpinfo(), they can discover a large amount of data, such as the IP address of the host, the version of the operating system, and the root directory of the web server.

   9.1. phpinfo () Output Reporting (HTTP) (Port: 80/tcp) Recommendation and Fixes:

   Remove phpinfo() test pages from the production environment (Tenable, 2003), as it leaves a chance of severe data breaches, or restrict access to the file only to internal IP addresses.

10. **SSL/TLS: Server Certificate / Certificate in Chain with RSA keys less than 2048 bits (Port: 443/tcp) Findings:**

    The system was found to be using a TLS certificate that is less than 2048 bits, which is below the current security standards (Tenable, 2013). Some browser SSL implementations may reject keys that have less than 2048 bits since it increases the odds of brute-force attacks with modern computing power.

    10.1. SSL/TLS: Server Certificate / Certificate in Chain with RSA keys less than 2048 bits (Port: 443/tcp) Recommendation and Fixes:

    Replace the certificate in the server and chain with the RSA key with a key, longer than the minimum requirement of 2048 bits (preferably ECDA P-256), and reissue any certificates that were signed by the older certificate (Tenable, 2013).

11. Weak SSH Host Key Algorithm(s) (SSH) (Port: 22/tcp) Findings:

SSH service is accepting outdated host keys, which include keys, such as DSA or short RSA keys, which can reduce the overall cryptographic strength of the server (Acunetix, 2025**).**

11.1. Weak SSH Host Key Algorithm(s) (SSH) (Port: 22/tcp) Recommendation and Fixes:

If the host is using weak keys, it is recommended that it migrated to either larger keys, more efficient algorithms, or both (Acunetix, 2025**).** For purposes of ensuring the server is as secure as possible, both are recommended.

12. Weak Key Exchange (KEX) Algorithm(s) Supported (SSH) (Port: 22/tcp) Findings:

There are two viable reasons as to why this issue appeared on the scan: first, if the host uses SHA1, or second, if it uses RSA 1024-bit modulus keys (Virtue, 2024). Both leave the system vulnerable to downgrade attacks, which can lead to the system being vulnerable to further attacks.

12.1. Weak Key Exchange (KEX) Algorithm(s) Supported (SSH) (Port: 22/tcp) Recommendation and Fixes:

To address this issue, edit the sshd_config file to restrict SSH to modern exchanges, such as curve25519-sha256 or diffie-hellman-group14-sha256, for improved security (Virtue, 2024). Ensure the SSH service is restarted and run an Nmap scan to verify the update.

13. SSL/TLS Renegotiation DoS Vulnerability (CVE-2011-1473) (Port: 5432/tcp) Findings:

This vulnerability stems from “OpenSSL before 0.9.8l, and 0.9.8m through 1.x” (Red Hat, 2011). The versions listed do not restrict client-initiated negotiations properly within the SSL and TLS protocols; this allows remote attackers to have the opportunity to cause a denial of

service through the service by performing numerous regenerations within a single session to the host.

13.1. SSL/TLS Renegotiation DoS Vulnerability (CVE-2011-1473) (Port: 5432/tcp)

Recommendation and Fixes:

Upgrade OpenSSL and disable client renegotiation within the configuration to prevent repeated handshake requests within one session. These recommendations will help circumvent the vulnerability mentioned.

14. /doc directory browsable (Port: 80/tcp) Findings:

The vulnerability found in the default configuration of Apache on Debian GNU/Linux sets the ServerRoot to user documents, which allows remote users to access not only the documentation files for the entire server (Pentest Tools, 2018), but the version of the installed programs as well, which can lead to a cascade of breaches.

14.1. /doc directory browsable (Port: 80/tcp) Recommendation and Fixes:

Use access restrictions for the /doc directory. In Apache, this can be found within the access.conf location, from there disable the directory listing by removing the “Options Indexes” directive.

15. QWikiWiki Directory Traversal Vulnerability (Port: 80/tcp) Findings:

The server runs QWikiwiki, a PHP-based wiki application. The remote version of this software has a “validation input flaw” that allows threat actors to read arbitrary files with the privileges of the web server (Pentest Tools, 2018). These vulnerabilities can lead to file path manipulation.

15.1. QWikiWiki Directory Traversal Vulnerability (Port: 80/tcp) Recommendations and Fixes:

Apply the latest software patch, sanitize path inputs, and limit who has access to the permissions on important directories. This allows a better security posture for QWikiWiki.

16. awiki <= 20100125 Multiple LFI Vulnerabilities (Port: 80/tcp) Findings:

Awiki is vulnerable to multiple Local File-Including (LFI) vulnerabilities because it failed to "properly sanitize user-supplied input" (Exploit, 2011). This gives attackers the opportunity to exploit this vulnerability to obtain sensitive information and execute arbitrary local scripts in the web server's process and can lead to other compromises in the system.

16.1. awiki <= 20100125 Multiple LFI Vulnerabilities (Port: 80/tcp) Recommendations and Fixes:

Other versions of awiki can be vulnerable to LFI vulnerabilities (Exploit, 2018), so it is imperative that this service is only kept if needed. If it is to be kept on the server, implement a strict path validation and upgrade to a secure, supported version of the software.

17. SSL/TLS: Certificate Expired (Port: 443/tcp) Findings:

This vulnerability means that the SSL/TLS certificate that is used by the host has finally expired. Once this certificate has expired, most web browsers that are used on the server will present the end-user with a security warning asking them to manually confirm the authenticity of the certificate chain (Acunetix, 2021). This can also lead to other issues, such

as some services silently refusing to connect with the server, leaving the host vulnerable to man-in-the-middle attacks.

17.1. SSL/TLS: Certificate Expired (Port: 443/tcp) Recommendations and Fixes:

It is highly recommended that the user address this issue as soon as possible and renew all expired certificates through the certificate authority and configure the monitoring so that the host is alerted to future expiration alerts before the certificate has fully expired.

18. FTP Unencrypted Cleartext Login (Port: 21/tcp) Findings:

The scan is showing that the File Transfer Protocol (FTP) is not encrypting its data and control connections (Fortra, 2024). This means all critical data, such as usernames and passwords, is being transmitted in clear text and can be easily intercepted by a network sniffer, also known as a man-in-the-middle attack.

18.1. FTP Unencrypted Cleartext Login (Port: 21/tcp) Recommendations and Fixes:

Replace FTP with SFTP (SSH File Transfer Protocol) or FTPS (File Transfer Protocol Secure) and enforce encrypted authentication for all file transfers.

19. Cleartext Transmission of Sensitive Information via HTTP (Port: 80/tcp) Findings:

Information over the Linux server is being sent over HTTP instead of HTTPS, which allows potential sensitive data to be sent over an unencrypted communication channel between the victim and its target system. (CVEdetails, 2006). An unauthorized actor can use a packet sniffer, with tools such as Wireshark, looking for session tokens in unencrypted traffic. If the token is captured, the attacker can exploit the information sent by the user.

19.1. Cleartext Transmission of Sensitive Information via HTTP (Port: 80/tcp)

Recommendation and Findings:

Enforce HTTPS for all forms using HTTP 301 redirects and ensure that the Strict-Transport-Security header is enabled.

20. SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection (Port:5432/tcp)

Findings:

The scan has flagged that the hidden Linux systems that support TLS 1.1 and TLS 1.0 protocols have been deprecated, respectively (Qualys, 2025). The use of these outdated protocols poses a security risk to the server because they lack the proper modern cryptographic keys to function in a secure manner.

20.1. SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection (Port:5432/tcp)

Recommendation and Fixes:

The vulnerability itself is straightforward; without the proper protocols, the system is at risk. Services that run on the specific port, 5432, need to be upgraded to their proper support, and must disable TLS 1.0/1.1 and below, and update to the proper TLS version.

21. Weak Encryption Algorithm(s) Supported (SSH) (Port: 22/tcp) Findings:

Currently, the remote SSH server is configured to allow weak encryption algorithms, or no algorithms at all (Tenable, 2016). This weakens the overall integrity of the server and can leak plaintext under certain conditions.

21.1. Weak Encryption Algorithm(s) Supported (SSH) (Port: 22/tcp) Recommendation and Fixes:

The recommended fix is to limit SSH to modern encryption algorithms only, such as

chacha-20-poly1305 and aes-gcm (Tenable, 2016), and to restart the SSH daemon to ensure that it is running on up-to-date encryption.

22. Apache HTTP Server ETag Header Information Disclosure Weakness (Port:80/tcp) Findings:

A vulnerability has been discovered in the Apache web server (HTTP) that is configured to use the FileETag directive (Security Orb, 2015). If this issue is exploited, it can provide the attacker with information that can be used to launch more devastating attacks against a target network.

22.1. Apache HTTP Server ETag Header Information Disclosure Weakness (Port:80/tcp) Recommendation and Fixes:

Disable ETags in the configuration file of Apache and use standard Cache-Control headers instead.

23. jQuery < 1.6.3 XSS Vulnerability (Port:80/tcp) Findings:

The remote web server on the Linux operating system is affected by an XSS attack vector. An attack actor can select elements using the location.hash in jQuery to allow someone to inject a script into the page (jQuery, 2011).

23.1. jQuery < 1.6.3 XSS Vulnerability (Port:80/tcp) Recommendation and Fixes:

Upgrade jQuery to a stable version, (3.7 or newer), and to enforce Content-Security-Policy (CSP) headers, which will control what content is loaded on websites to prevent any cross-site scripting.

24. Apache HTTP Server 'httpOnly' Cookie Information Disclosure Weakness (Port:80/tcp) Findings:

The HTTP web server is susceptible to another information disclosure vulnerability. The current version of Apache HTTP (2.0.64 and lower) that is running on the current OS due to the fact that if an attacker were to send an HTTP header long enough to exceed the server limit, it could cause the web server to respond with HTTP 400 (Tenable, 2012), which at default displays HTTP header and values, leaving the server susceptible to XSS attacks and compromise of 'httpOnly' cookies.

24.1. Apache HTTP Server 'httpOnly' Cookie Information Disclosure Weakness (Port:80/tcp) Recommendation and Fixes:

Despite the extensive list of consequences from this vulnerability, the fix is simple: upgrade to Apache 2.0.65 / 2.2.22 or later.

25. phpMyAdmin 'error.php' Cross-Site Scripting Vulnerability (Port:80/tcp) Findings:

phpMyAdmin, a web interface for MySQL and MariaDB, has an identified Cross-Site Scripting (XSS) vulnerability within the getIndexesProblems function (SNYK, 2025). This vulnerability arises from insufficient input sanitization in the check tables feature, which allows attackers to inject malicious scripts that can be executed if the user unknowingly triggers it by doing mundane tasks, such as crafting a table or a database name.

25.1. phpMyAdmin 'error.php' Cross-Site Scripting Vulnerability (Port:80/tcp) Recommendation and Fixes:

The recommended fix for this is straightforward as well: upgrade the phpMyAdmin/phpMyAdmin to version 5.2.2. or higher to prevent the XSS vulnerability.

26. SSL/TLS: Diffie-Hellman Key Exchange Insufficient DH Group Strength Vulnerability (Port: 80/tcp) Findings:

The current TLS service on the hidden Linux server uses weak Diffie-Hellman (DH) parameters that fall below the Diffie-Hellman small prime 1024 bits, reducing the key exchange entropy and allowing the Logjam attack (MyF5, 2020).

26.1. SSL/TLS: Diffie-Hellman Key Exchange Insufficient DH Group Strength Vulnerability (Port: 80/tcp) Recommendation and Fixes:

Regenerate the DH parameters using 2048-bit or stronger keys and restrict the ciphers that the host uses to Elliptic Curve Diffie-Hellman Ephemeral (ECDHE) (MyF5, 2020). This will ensure the integrity of the system is able to meet modern cryptographic standards.

27. SSL/TLS: Certificate Signed Using a Weak Signature Algorithm (Port: 443/tcp) Findings:

The current SSL/TLS certificate chain is using a cryptographically weak hashing algorithms, for example, MD2, MD4, MD5, or SHA1 (Tenable, 2009). These outdated signature algorithms are vulnerable to collision attacks, allowing an attacker to exploit the weak ciphers to generate a new certificate with the same digital signature, thereby impersonating the affected service and enabling man-in-the-middle attacks or unauthorized data interception.

27.1. SSL/TLS: Certificate Signed Using a Weak Signature Algorithm (Port: 443/tcp) Recommendation and Fixes:

Reissue the certificate using SHA-256 or stronger algorithms to comply with the current

Certificate Authority/Browser Forum's (CA/B Forum) standards (GlobalSign, 2012), which will ensure that the operating system can properly handle modern cyber-attacks.

Annexes

The following annexes support evidence for the vulnerability assessment, including the required Greenbone and Nmap scan results with timestamps and host details verifying authenticity.

Greenbone Scan Results

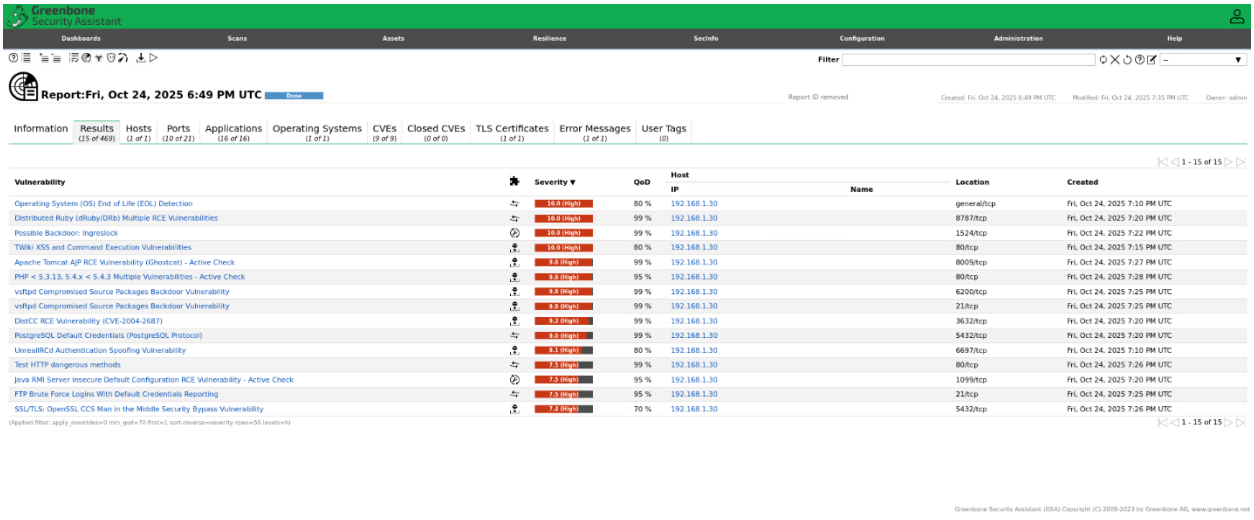


Figure 1. Greenbone Scan Results – High Findings (Linux)

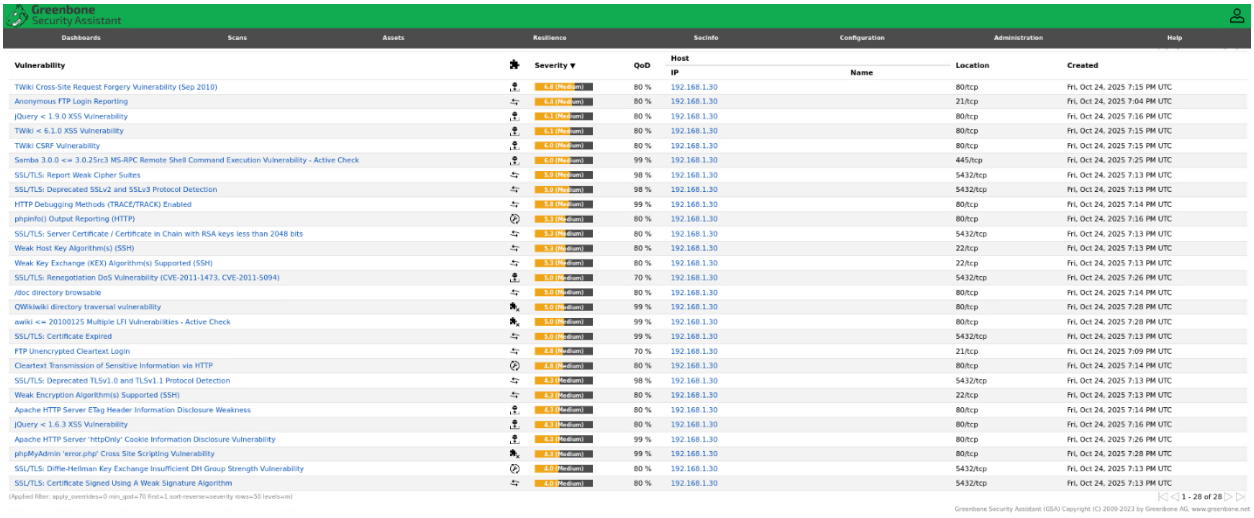


Figure 2. Greenbone Scan Results – Medium Findings (Linux)

Nmap Scan Results – Linux Server

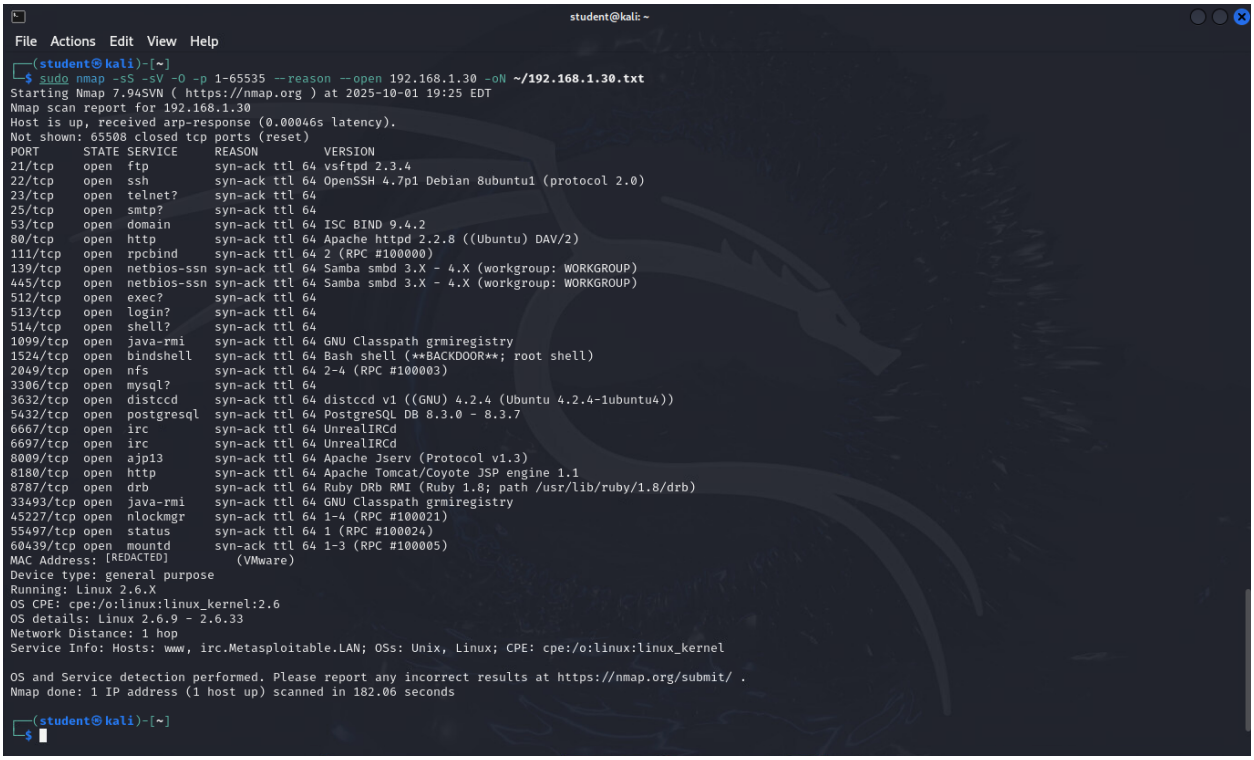


Figure 3. Nmap Scan Results – Linux Host 192.168.1.30

Nmap Scan Results – Windows Server

No findings.

Vulnerability Ranking Scale

The vulnerability ranking scale used by the Greenbone Vulnerability Manager (GVM) 23.6.2, uses the Common Vulnerability Scoring System (CVSS) version 3.1. The purpose of the CVSS is to assign severity levels to properly prioritize specific vulnerabilities by the risk they can impose on the respective operating system. (Schlosser, 2021). To rank vulnerabilities efficiently and consistently, CVSS uses a standardized numerical scoring range from 0.0 to 10.0, which is then organized into three qualitative categories: low (0.1-3.9), medium (4.0-6.9), and high (7.0-10).

The scoring model used by CVSS calculates severity based on three metric groups: base, temporal, and environmental (FIRST, 2015). The base metric group breaks the severity down by the characteristic of vulnerability that does not change over time, such as how a system can be exploited, how complex the attack is, the privileges required for the attack to occur, the user interaction, and the overall impact it has on confidentiality, integrity, and availability of the server. The temporal group considers factors that can evolve, such as the presence of exploit code, the availability of patches for the specific issue, awareness, and thus vendor confirmation. Finally, the environmental metric represents characteristics that apply to a specific IT environment and, overall, allows the score to accurately reflect the importance of the affected program within the organization's specific environment.

Greenbone Vulnerability Manager typically uses only the base score metric (Schlosser, 2021), as it is often the most useful metric in a report because it reflects inherent technical risk. High findings represent vulnerabilities with sufficient factors for a successful attack (Schlosser, 2021); for example, the attacker must be able to gain unauthorized access or execute incidental code and consequently demand immediate mitigation on the server. Medium findings follow the same concept: they represent partial pieces of an attack —weaknesses that could be used to piece together larger attacks if left unresolved. Low findings are minor issues with minimal risk but should still be corrected during routine maintenance. The report focuses on high and medium issues, as they require immediate attention.

References

Acunetix. (2019a). *SSL Certificate Is About to Expire - Vulnerabilities - Acunetix*. Acunetix. https://www.acunetix.com/vulnerabilities/web/ssl-certificate-is-about-to-expire/

Acunetix. (2019b). *TLS/SSL certificate key size too small - Vulnerabilities - Acunetix*. Acunetix. https://www.acunetix.com/vulnerabilities/web/tls-ssl-certificate-key-size-too-small/

Apache. (2017). *httpd 2.2 vulnerabilities - The Apache HTTP Server Project*. Apache.org. https://httpd.apache.org/security/vulnerabilities_22.html

Carnegie Mellon University. (2008, September 12). *CERT/CC Vulnerability Note VU#362012*. Cert.org. https://www.kb.cert.org/vuls/id/362012

CVE. (2011, April 27). *CVE-2011-1578*. Cve.org. https://www.cve.org/CVERecord?id=CVE-2011-1578

CVE. (2025). *CVE-2018-20212*. Cve.org. https://www.cve.org/CVERecord?id=CVE-2018-20212

CVEdetails. (2025). *CWE 319 Cleartext Transmission of Sensitive Information*. Cvedetails.com. https://www.cvedetails.com/cwe-details/319/Cleartext-Transmission-of-Sensitive-Information.html

FIRST. (2015). *CVSS v3.0 Specification Document*. FIRST — Forum of Incident Response and Security Teams. https://www.first.org/cvss/v3-0/specification-document

Forta. (2025a). *Finding and Fixing Vulnerabilities in Deprecated SSL Protocol Usage, a Medium Risk Vulnerability*. Fortra.com. https://www.fortra.com/resources/vulnerabilities/deprecated-ssl-protocol-usage

Forta. (2025b). *Finding and Fixing Vulnerabilities in FTP Clear Text Authentication, a Low-Risk Vulnerability*. Fortra.com. https://www.fortra.com/resources/vulnerabilities/ftp-clear-text-authentication

Group, I. (2019, December 6). *CA/B Forum Guidelines*. GlobalSign. https://www.globalsign.com/en/ssl-information-center/ca-network-security-practices

INCIBE. (2024). *CVE-2010-2075 | INCIBE-CERT | INCIBE*. Incibe.es. https://www.incibe.es/en/incibe-cert/early-warning/vulnerabilities/cve-2010-2075

jQuery Foundation - jquery.org. (2011, September). *jQuery 1.6.3 Released | Official jQuery Blog*. Jquery.com. https://blog.jquery.com/2011/09/01/jquery-1-6-3-released/

Lee, B. (2022, January 31). *TCP port 21 FTP vulnerabilities*. Specops Software. https://specopssoft.com/blog/tcp-port-21-ftp-vulnerabilities/

Logan, M. (2020, March 10). *Busting Ghostcat: Analysis of CVE-2020-1938*. Trend Micro. https://www.trendmicro.com/en_us/research/20/c/busting-ghostcat-an-analysis-of-the-apache-tomcat-vulnerability-cve-2020-1938-and-cnvd-2020-10487.html

Mammen, B., Guan, Y., & Fu, Y. (2020, September 15). *Network Attack Trends: Attackers Leveraging High Severity and Critical Exploits*. Unit42. https://unit42.paloaltonetworks.com/network-attack-trends/

MITRE. (2018). *CWE - Industry News Coverage - 2011 Archive*. Mitre.org. https://cwe.mitre.org/news/archives/industrynews2011.html

MITRE. (2025). *MITRE ATT&CK*. Mitre.org. https://attack.mitre.org/

muuratsalo. (2011, August 15). *awiki 20100125 - Multiple Local File Inclusions*. Exploit Database. https://www.exploit-db.com/exploits/36047

My F5. (2025). *myF5*. F5.com. https://my.f5.com/manage/s/article/K89130356

NIST. (2004). *NVD - CVE-2004-2687*. Nvd.nist.gov. https://nvd.nist.gov/vuln/detail/CVE-2004-2687

NIST. (2017). *NVD - cve-2017-3241*. Nist.gov. https://nvd.nist.gov/vuln/detail/cve-2017-3241

NIST. (2024). *NVD - CVE-2009-4492*. Nist.gov. https://nvd.nist.gov/vuln/detail/CVE-2009-4492

Oracle. (2017). *Oracle Critical Patch Update Advisory - January 2017*. Oracle.com. https://www.oracle.com/security-alerts/cpujan2017.html

OWASP. (2009). *WSTG - Latest | OWASP Foundation*. Owasp.org. https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/02-Configuration_and_Deployment_Management_Testing/06-Test_HTTP_Methods

OWASP. (2017). *Authentication · OWASP Cheat Sheet Series*. Owasp.org. https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

Pentest Tools. (2018a, January 2). */Doc directory browsable (CVE-1999-0678)*. Pentest-Tools.com. https://pentest-tools.com/vulnerabilities-exploits/doc-directory-browsable_14019

Pentest Tools. (2018b, January 2). *Pentest-Tools.com*. Pentest-Tools.com. https://pentest-tools.com/vulnerabilities-exploits/ssl-tls-openssl-ccs-man-in-the-middle-security-bypass-vulnerability_9744

Pentest Tools. (2018c, January 2). *Pentest-Tools.com*. Pentest-Tools.com. https://pentest-tools.com/vulnerabilities-exploits/qwikiwiki-directory-traversal-vulnerability_14178

PostgreSQL. (2025, May 8). *Chapter 53. Frontend/Backend Protocol*. PostgreSQL Documentation. https://www.postgresql.org/docs/current/protocol.html

Qualys. (2025). *Qualys Customer Portal*. Qualys.com. https://success.qualys.com/support/s/article/000007911

Rapid7. (2018, May 30). *VSFTPD v2.3.4 Backdoor Command Execution*. Rapid7. https://www.rapid7.com/db/modules/exploit/unix/ftp/vsftpd_234_backdoor/

Red Hat. (2024, August 7). *What is the meaning of "SSL Medium/Weak Strength Cipher Suites Supported" reported by a security scanner? - Red Hat Customer Portal*. Red Hat Customer Portal. https://access.redhat.com/solutions/24717

Red Hat. (2025a). *cve-details*. Redhat.com. https://access.redhat.com/security/cve/cve-2021-30047

Red Hat. (2025b). *cve-details*. Redhat.com. https://access.redhat.com/security/cve/cve-2007-2447

Red Hat. (2025c). *cve-details*. Redhat.com. https://access.redhat.com/security/cve/cve-2011-1473

Rohan Timalsina. (2024, August 23). *The Risks of Running an End-of-Life OS – And How to Manage It*. TuxCare. https://tuxcare.com/blog/eol-software/

Schlosser, K. (2021, October 22). *Full CVSSv3x Coverage in the Greenbone Feeds*. Greenbone. https://www.greenbone.net/en/blog/full-cvssv3x-coverage-in-the-greenbone-feeds/

SecurityOrb_Staff. (2015, June 2). *Apache Web Server ETag Header Information Disclosure Weakness | SecurityOrb.com*. SecurityOrb.com | the Information Security, Digitial Privacy & Internet Safety Website... https://securityorb.com/apache-web-server-etag-header-information-disclosure-weakness/

SNYK. (2025). *Snyk Vulnerability Database | Snyk*. Learn More about Composer with Snyk Open-Source Vulnerability Database. https://security.snyk.io/vuln/SNYK-PHP-PHPMYADMINPHPMYADMIN-8660826

Stanley, L. (2025). *End-of-Life (EOL) Software: Definition, Risks, & Solutions*. Liquid Web. https://www.liquidweb.com/blog/eol-software/

Tenable. (2003a). *HTTP TRACE / TRACK Methods Allowed*. Www.tenable.com. https://www.tenable.com/plugins/nessus/11213

Tenable. (2003b). *Web Server info.php / phpinfo.php Detection*. Www.tenable.com. https://www.tenable.com/plugins/nessus/11229

Tenable. (2014). *SSL Certificate Chain Contains RSA Keys Less Than 2048 bits*. Tenable.com. https://www.tenable.com/plugins/nessus/69551

Tenable. (2016). *SSH Weak Algorithms Supported*. Tenable.com. https://www.tenable.com/plugins/nessus/90317

Tenable. (2017). *SSL Certificate Signed Using Weak Hashing Algorithm*. Tenable.com. https://www.tenable.com/plugins/nessus/35291

Tenable. (2020). *JQuery < 1.9.0 XSS*. Tenable.com. https://www.tenable.com/plugins/nessus/135011

Twiki. (2025). *SecurityAlert-CVE-2010-3841 < Codev < TWiki*. Twiki.org. https://twiki.org/cgi-bin/view/Codev/SecurityAlert-CVE-2010-3841

Virtue. (2022, June 17). *SSH Weak Key Exchange Algorithms Enabled*. Virtue Security. https://www.virtuesecurity.com/kb/ssh-weak-key-exchange-algorithms-enabled/